

BASE DE CONOCIMIENTO

AGENTE DE IA - RETO No. 2

Aplicacion Web para Autodiagnostico de Cumplimiento
de Proteccion de Datos - Ley 1581 de 2012 (Colombia)

EMPRESA RETADORA: CAVALTEC

1. CONTEXTO REGULATORIO: LEY 1581 DE 2012

La Ley 1581 de 2012 es la ley colombiana de proteccion de datos personales. Establece principios, derechos y obligaciones para el tratamiento adecuado de datos personales de personas naturales.

Principios fundamentales

Finalidad: Los datos deben recolectarse con un proposito legitimo e informado al titular.

Necesidad/Minimizacion: Solo se recolectan los datos estrictamente necesarios.

Veracidad: Los datos deben ser exactos y actualizados.

Transparencia: El titular tiene derecho a conocer el uso de sus datos.

Acceso restringido: Solo personas autorizadas acceden a los datos.

Seguridad: Se deben adoptar medidas tecnicas y administrativas de proteccion.

Confidencialidad: Quienes traten datos deben guardar reserva sobre ellos.

Derechos de los titulares (ARCO+)

- Acceder a sus datos personales
- Rectificar datos incorrectos
- Cancelar/Suprimir datos
- Oponerse al tratamiento
- Ser informado sobre el uso de sus datos
- Presentar quejas ante la Superintendencia de Industria y Comercio (SIC)

Obligaciones de las organizaciones

- Tener una Politica de Tratamiento de Datos Personales documentada y publicada.
- Definir las finalidades del tratamiento.
- Designar un Responsable/Encargado del tratamiento (Oficial de Proteccion de Datos).
- Implementar medidas de seguridad tecnicas y organizativas.
- Atender solicitudes de los titulares en los plazos legales.
- Registrar bases de datos ante la SIC (cuando aplique).

2. PRIVACY BY DESIGN (Privacidad desde el Diseno)

El reto se enfoca en la FASE DE DISEÑO. Privacy by Design implica integrar la privacidad desde la concepcion del producto

o proceso, no como un elemento anadido posterior.

Principio	Significado practico
Proactivo, no reactivo	Prevenir problemas antes de que ocurran
Privacidad por defecto	El sistema recoge el minimo de datos por defecto sin accion del usuario
Privacidad embebida	No es un anadido: es parte arquitectural del sistema
Funcionalidad total	Privacidad sin sacrificar funcionalidades del negocio
Seguridad extremo a extremo	Proteccion durante todo el ciclo de vida del dato
Visibilidad y transparencia	El sistema opera abiertamente y puede ser verificado
Respeto al usuario	Centrado en los intereses del titular del dato

3. CUESTIONARIO DE DIAGNOSTICO - ESTRUCTURA COMPLETA

Bloque 1: Política de Datos Personales - max. 40%

LOGICA CONDICIONAL: La pregunta 1 es padre. Si la respuesta es NO, las preguntas 2 a 5 se deshabilitan automaticamente y su peso cae a 0. Si es SI, se despliegan y pueden sumar hasta 40%.

N.	Pregunta	Peso	Logica
1	Cuenta con una politica de tratamiento de datos personales?	0-40%	Pregunta padre; hereda peso de Q2-Q5
2	La politica esta documentada y publicada en medio de facil acceso?	10%	Hija de Q1
3	Define las finalidades del tratamiento de datos?	10%	Hija de Q1
4	Incluye los derechos de los titulares?	10%	Hija de Q1
5	Menciona como ejercer los derechos de los titulares?	10%	Hija de Q1

Bloque 2: Privacidad desde el Diseno - max. 36%

N.	Pregunta	Peso
6	Incorpora evaluaciones de impacto (Privacy Impact Assessments - PIA)?	12%
7	Aplica tecnicas de minimizacion de datos?	12%
8	Configura sus sistemas para recopilar el minimo de datos por defecto?	12%

Bloque 3: Gobernanza - max. 24%

N.	Pregunta	Peso	Nota
9	Cuenta con un sistema de administracion de riesgos?	16%	Independiente
10	Cuenta con un oficial de proteccion de datos personales?	8%	Independiente
11	Esta designado formalmente?	-	Complementaria: no suma al total

Resumen de pesos por bloque

Bloque 1 - Política de datos personales:	max. 40%
Bloque 2 - Privacy by Design:	max. 36%
Bloque 3 - Gobernanza:	max. 24%

TOTAL MAXIMO ALCANZABLE:	100%

4. LOGICA DE CALCULO DEL PORCENTAJE DE CUMPLIMIENTO

Cumplimiento (%) = SUMA (peso_pregunta x respuesta_binaria)

Donde respuesta_binaria:

SI = 1 (suma el peso completo de la pregunta)

NO = 0 (no suma)

Pregunta deshabilitada por condicion = 0

Caso especial Q1:

Q1 = NO -> Q2+Q3+Q4+Q5 = 0 automaticamente

Q1 = SI -> Q2+Q3+Q4+Q5 pueden sumar hasta 40%

Q1 por si misma NO tiene peso propio; actua como habilitador

Q11 = complementaria: se registra pero NO altera el porcentaje.

Rangos de interpretacion recomendados

Rango	Nivel	Interpretacion
0% - 39%	Critico	No conformidad grave con Ley 1581. Exposicion legal alta.
40% - 59%	Bajo	Cumplimiento parcial. Riesgo alto. Brechas estructurales.
60% - 79%	Medio	Avances visibles pero con brechas importantes pendientes.
80% - 99%	Alto	Buen nivel de cumplimiento. Ajustes menores requeridos.
100%	Optimo	Cumplimiento total en la fase de diseno.

5. MODULOS DE LA APLICACION

Modulo 1: Autenticacion y Acceso

Funcionalidad	Detalle
OAuth Login	Google, Microsoft (Hotmail/Outlook) u otros proveedores
Roles	Administrador / Empresa evaluada / Auditor
Sesiones seguras	JWT tokens, cifrado, manejo seguro de sesiones

Detalle de roles:

- Administrador: Gestion completa de la plataforma, acceso a todas las empresas
- Empresa evaluada: Solo ve sus propios diagnosticos, puede responder cuestionarios
- Auditor: Puede revisar resultados de empresas asignadas, sin modificar datos

Modulo 2: Empresa

Funcionalidad	Detalle
Registro de datos basicos	Nombre, NIT, sector, tamano de la empresa
Multiempresa	Cada empresa puede tener multiples evaluaciones historicas

Modulo 3: Diagnostico (Cuestionario)

- 11 preguntas estructuradas en 3 bloques segun la Ley 1581
- Logica condicional: Q1 habilita/deshabilita Q2-Q5
- Cada pregunta tiene respuesta Si/No
- Q11 es complementaria (solo informativa, no suma al porcentaje)
- Calculo automatico del porcentaje al finalizar

Modulo 4: Inteligencia Artificial

Categoria	Funcionalidad	Descripcion
Asistencia	Explicacion de preguntas	La IA traduce terminos legales a lenguaje sencillo
Apoyo	Orientacion para responder	Sugiere como interpretar cada pregunta
Recomendacion	Plan de accion	Genera acciones concretas y priorizadas para cerrar brechas
Analisis	Interpretacion de resultados	Explica el nivel de cumplimiento obtenido en contexto legal

Ejemplos de lo que la IA debe poder hacer:

- Explicar que es un PIA en terminos simples para una PYME
- Decir que significa 'minimizacion de datos' con ejemplos reales de negocio
- Generar un plan de accion priorizado si la empresa obtuvo 40% de cumplimiento
- Explicar por que una brecha especifica es critica segun la Ley 1581
- Sugerir como documentar y publicar una politica de datos correctamente

Modulo 5: Resultados

Categoria	Funcionalidad	Detalle
Indicador	Nivel de cumplimiento (%)	Basado en respuestas positivas ponderadas
Visualizacion	Medidor tipo velocimetro	Rango 0-100%, colores por nivel (gauge)
Brechas	Identificacion automatica	Lista de preguntas respondidas como NO

Recomendaciones

Plan de mejora

Acciones priorizadas por bloque

Reportes

Exportables

PDF descargable o dashboard interactivo

6. SEGURIDAD DE LA APLICACION

OWASP Top 10 aplicables

Riesgo OWASP	Mitigacion requerida
Inyeccion (SQL/XSS)	Sanitizacion y validacion estricta de entradas
Autenticacion rota	OAuth seguro + JWT bien configurado + sesiones con expiracion
Exposicion de datos sensibles	Cifrado en transito (HTTPS/TLS) y en reposo
Control de acceso roto	Roles y permisos aplicados server-side, no solo en UI
Configuracion incorrecta	Variables de entorno, sin hardcoding de secretos en codigo
CSRF	Tokens anti-CSRF en formularios y peticiones mutantes

Principios de Privacy by Design aplicados al codigo

- No almacenar datos innecesarios del usuario
- Datos de empresas aislados por tenant (arquitectura multiempresa)
- Logs de auditoria para acciones sensibles (quien, que, cuando)
- Consentimiento explicito antes de procesar datos personales
- Política de retencion de datos: definir cuanto tiempo se guardan

7. NIVELES DE PARTICIPACION DEL RETO

Nivel	Nombre	Funcionalidades requeridas
1 - Basico	Nivel Basico	Formulario de diagnostico funcional Calculo del resultado en % Interfaz simple
2 - Intermedio	Nivel Intermedio	Login con OAuth Dashboard con resultados Logica condicional Q1->Q2-Q5 Recomendaciones basicas
3 - Avanzado	Nivel Avanzado	IA para asistencia generativa Multiempresa Roles diferenciados Reportes PDF Historico Seguridad avanzada

8. CRITERIOS DE EVALUACION DEL RETO

Categoria	Peso	Aspectos evaluados
Alineacion con Ley 1581	20%	Correcta interpretacion normativa, coherencia del diagnostico
Desarrollo tecnico	20%	Calidad de codigo, arquitectura, buenas practicas
Seguridad	15%	Controles OWASP, autenticacion/autorizacion bien implementados
Uso de IA	15%	Utilidad real, precision de recomendaciones, valor agregado
Experiencia de usuario	10%	Facilidad de uso, diseno intuitivo y accesible
Calidad del diagnostico	10%	Claridad de resultados, accionabilidad de recomendaciones
Innovacion	10%	Diferenciadores, funcionalidades adicionales no requeridas

9. PREGUNTAS FRECUENTES - RESPUESTAS DEL AGENTE**SOBRE LA NORMATIVA****P: Que es la Ley 1581?**

R: Ley colombiana de proteccion de datos personales (2012). Regula como las organizaciones deben recolectar, almacenar, usar y eliminar datos personales de ciudadanos colombianos.

P: Que es un titular?

R: La persona natural cuyos datos personales son objeto de tratamiento por parte de una organizacion.

P: Que es un PIA?

R: Privacy Impact Assessment (Evaluacion de Impacto en Privacidad): analisis previo que se realiza antes de lanzar un sistema o proceso para identificar riesgos a la privacidad y mitigarlos.

P: Que es minimizacion de datos?

R: Principio que obliga a recolectar unicamente los datos estrictamente necesarios para la finalidad declarada. Ejemplo: si solo necesitas el correo, no pidas telefono y direccion.

P: Que es el oficial de proteccion de datos?

R: Persona responsable dentro de la organizacion de velar por el cumplimiento de la normativa, atender solicitudes de titulares y ser punto de contacto ante la SIC.

P: Que es Privacy by Design?

R: Enfoque que integra la privacidad desde la concepcion del producto o proceso, haciendo que la proteccion de datos sea la configuracion predeterminada, no un anadido posterior.

P: Que es la SIC?

R: Superintendencia de Industria y Comercio: entidad colombiana que regula y supervisa el cumplimiento de la Ley 1581.

SOBRE EL CUESTIONARIO**P: Por que la pregunta 1 tiene peso 0-40%?**

R: Porque es una pregunta padre. Por si sola no suma; su peso lo determinan las preguntas hijas 2-5. Si se responde SI, habilita las hijas que suman hasta 40%. Si se responde NO, el total del bloque es 0%.

P: Que pasa si respondo NO a Q1?

R: Las preguntas 2 a 5 se deshabilitan automaticamente y su peso cae a 0. La empresa no puede sumar puntos en el Bloque 1.

P: Cuantas preguntas suman al porcentaje total?

R: 10 preguntas (Q1 a Q10). La Q11 es complementaria e informativa: se registra pero no altera el porcentaje.

P: Cual es el puntaje maximo?

R: 100%. Distribuido en: Bloque 1 (40%) + Bloque 2 (36%) + Bloque 3 (24%).

P: Cual bloque tiene mayor peso?

R: El Bloque 1 (Politica de datos personales) con hasta 40%, seguido de Privacidad desde el diseno (36%) y Gobernanza (24%).

SOBRE LA IMPLEMENTACION TECNICA**P: Que proveedores OAuth se requieren?**

R: Como minimo Google y Microsoft (Hotmail/Outlook). Se pueden anadir otros como GitHub o LinkedIn.

P: Que roles existen en el sistema?

R: Administrador (gestion total), Empresa evaluada (solo sus diagnosticos), Auditor (revision sin modificar).

P: Puede una empresa tener varios diagnosticos?

R: Si. El sistema es multiempresa y guarda el historico de evaluaciones para comparar evolucion en el tiempo.

P: Como se visualiza el resultado?

R: Con un medidor tipo velocimetro (gauge) de 0 a 100%, codificado por colores segun el rango.

P: Se puede exportar el reporte?

R: Si, en formato PDF descargable o desde el dashboard interactivo.

P: Donde se usa la IA en el sistema?

R: Para explicar preguntas en lenguaje simple, orientar al usuario sobre como responder, generar planes de accion para cerrar brechas, e interpretar el nivel de cumplimiento obtenido.

10. STACK TECNICO RECOMENDADO

Frontend:	React / Vue / Angular + Chart.js (gauge) + TailwindCSS
Backend:	Node.js/Express FastAPI (Python) Spring Boot
Auth:	NextAuth.js / Auth0 / Firebase Auth (OAuth)
Base datos:	PostgreSQL (multiempresa con row-level security) o Supabase
IA:	Claude API / OpenAI API - explicaciones y recomendaciones
Seguridad:	HTTPS, JWT, CORS, Helmet.js, rate limiting, CSRF tokens
Export PDF:	jsPDF / Puppeteer / WeasyPrint
Deploy:	Vercel / Railway / Render / AWS

Arquitectura multiempresa recomendada

Cada empresa (tenant) debe tener sus datos completamente aislados. Opciones:

- Row-Level Security (RLS) en PostgreSQL/Supabase - RECOMENDADO
- Schema separado por tenant - mayor aislamiento, mayor complejidad
- Base de datos separada por tenant - maxima seguridad, alto costo operativo

Flujo tipico de la aplicacion (paso a paso)

1. Usuario accede -> Login con OAuth (Google/Microsoft)
2. Sistema asigna rol -> Administrador / Empresa / Auditor
3. Empresa registra datos basicos -> NIT, nombre, sector, tamano
4. Empresa inicia diagnostico -> Cuestionario 11 preguntas
 - a. Q1 = NO -> Q2-Q5 se bloquean automaticamente
 - b. IA disponible en cada pregunta para explicar y orientar
5. Sistema calcula porcentaje -> suma pesos de respuestas SI
6. Dashboard muestra:
 - Gauge 0-100% con nivel de cumplimiento
 - Brechas identificadas (preguntas respondidas NO)
 - Plan de accion generado por IA
 - Recomendaciones priorizadas por bloque
7. Exportar reporte en PDF
8. Guardar historico -> comparar con evaluaciones anteriores

Resultado esperado del reto

- Entender su nivel de cumplimiento en la fase de diseno de proteccion de datos
- Identificar rapidamente sus debilidades (brechas)
- Recibir orientacion clara y accionable para mejorar
- Adoptar principios de Privacy by Design en sus procesos

Documento generado para uso del agente de IA - Reto No. 2 CAVALTEC 2026